Network Forensic Analysis of a RIG Exploit Kit Drive-by Infection Delivering KPOT Stealer: A Packet-Capture Case Study

Cyber Security – Theory CA-2 (Part 2), Unit 4: Case Study Report

B.Tech CSE, Semester VII, Batch 2023–27

Group Number (B.Tech Project Group)	G__
Topic Selected	Network forensics and incident response: investigation of an exploit-kit drive-by download and credential-stealing malware (KPOT Stealer) from a packet capture
Faculty	Dr. Pooja Bagane, Dr. Jitendra Rajpurohit
Submission Date	10 October 2026

Sr.	Student Name	Roll / Enrollment No.
1	Sajal Thapliyal	[Roll / Enrollment No.]
2	[Member 2 name]	[Roll / Enrollment No.]
3	[Member 3 name]	[Roll / Enrollment No.]
4	[Member 4 name]	[Roll / Enrollment No.]

Abstract

Drive-by downloads delivered through exploit kits remain a classic route for credential-stealing malware, and a packet capture is often the only evidence available when endpoint telemetry is missing. This report presents a network-forensic case study of a publicly released training capture (Phenomenoc, 22 June 2019) in which a Windows workstation on a 10.0.76.0/24 enterprise LAN was compromised. Using Wireshark, IDS alert correlation and cryptographic hashing, we followed a structured methodology aligned with NIST SP 800-86 and 800-61, the Cyber Kill Chain and MITRE ATT&CK. We identified the infected host (10.0.76.109), reconstructed an unencrypted HTTP infection chain in which a RIG exploit kit landing page, a Flash object and an executable payload were served by 37.46.135.170, verified the retrieved executable by its SHA-256 hash, and characterised post-infection command-and-control (C2) activity consisting of large HTTP POST uploads to gate.php on 8.209.83.76 (fghjkmgru34.site). IDS signatures attribute this activity to KPOT Stealer. We also test and reject alternative hypotheses, including attribution to Emotet and the involvement of a second busy host. The report provides reproducible filters and commands, an evidence register, a defanged IOC set and prioritised containment actions, and argues that stealer incidents require credential and session revocation in addition to re-imaging.

Keywords

Network forensics; packet analysis; Wireshark; exploit kit; RIG EK; KPOT Stealer; indicators of compromise; incident response; command and control; MITRE ATT&CK.

1. Introduction

1.1 Background and relevance

Network forensics is the capture, recording and analysis of network events to discover the source of attacks and reconstruct what happened [1, 2]. It is especially valuable for endpoint compromises in which logs are incomplete or have been tampered with, because the network record of an infection is difficult for malware to erase. Among the most common outcomes of web-borne compromise is infection by an *information stealer*: malware that harvests saved passwords, browser data, wallets and files and sends them to an attacker-controlled server [3].

The topic remains highly relevant. Flashpoint data reported in 2026 recorded 7.4 million devices infected with infostealers in the first half of 2026, a 27% increase over the previous six months, and roughly 1.7 billion credentials harvested in that period [4]. Flare's 2026 analysis of 18.7 million infostealer logs found that more than one in ten infections already contained enterprise single sign-on or identity-provider credentials [5]. Although Adobe Flash, the plug-in abused in this case, reached end of life at the end of 2020 [6], the investigative workflow (triage, host attribution, delivery reconstruction, payload verification and C2 analysis) transfers directly to present-day infostealer campaigns, whose delivery methods have changed while their objective, credential theft, has not.

1.2 Problem statement

A security team receives IDS alerts and a packet capture from a LAN segment (10.0.76.0/24, domain phenomenoc.com, domain controller 10.0.76.6, gateway 10.0.76.1) [7]. The team must determine which host was infected, how the malware arrived, what it was, what it did afterwards, and what to do about it, using only passive network evidence and one extracted executable.

1.3 Objectives

- O1: Identify the infected host (IP address, MAC address, host name) and the associated Windows user account.
- O2: Determine the malware delivery method and the IP address used for delivery.
- O3: Extract and cryptographically fingerprint the executable retrieved from the infected host.
- O4: Use IDS alerts to determine the malware type and characterise post-infection traffic.
- O5: Produce a defanged IOC list and map observed behaviour to the Cyber Kill Chain and MITRE ATT&CK.
- O6: Recommend containment, eradication, recovery and prevention actions justified by the findings.

1.4 Contributions and organisation

The contributions are (i) a documented, reproducible methodology for passive investigation of a drive-by-to-stealer infection; (ii) a corroborated reconstruction of the infection chain; (iii) an explicit elimination of competing hypotheses (malware family and host identity); and (iv) evidence-based remediation guidance. Section 2 reviews related work, Section 3 presents the methodology, Section 4 the implementation, Section 5 the results and discussion, and Section 6 concludes.

2. Literature Review

2.1 Incident-response and forensic frameworks

NIST SP 800-61 Rev. 2 organises incident handling into preparation, detection and analysis, containment, eradication and recovery, and post-incident activity [8], while the SANS handler's handbook expresses a similar six-step cycle [9]. NIST SP 800-86 describes the forensic process as collection, examination, analysis and reporting, and stresses evidence preservation and data integrity [2]. For adversary modelling, the Intrusion Kill Chain decomposes an attack into reconnaissance, weaponisation, delivery, exploitation, installation, command and control, and actions on objectives [10], and MITRE ATT&CK provides a common vocabulary of tactics and techniques for describing observed behaviour [11]. Practitioner texts on network security monitoring and packet analysis supply the technical foundation for applying these frameworks to captured traffic [1, 12, 13].

2.2 Drive-by downloads and exploit kits

Provos *et al.* examined how web content compromises browsers, identifying vectors such as server compromise, user-contributed content, advertising and third-party widgets [14], and later measured malware-distribution infrastructure at scale, showing how compromised sites funnel visitors through intermediate nodes to exploit servers [15]. Grier *et al.* documented the "exploit-as-a-service" ecosystem, in which exploit-kit operators sell infection capacity to separate parties who supply the payload [16]. Kotov and Massacci analysed exploit kits as software artefacts, characterising their exploit selection and evasion features [17], and Nappa *et al.* studied the infrastructure of exploit servers and the effectiveness of abuse reporting [18]. This ecosystem explains why a single visit to a web page can silently chain a landing page, an exploit and a payload download, the pattern reconstructed in this case. Exploit kits of the period typically abused plug-in and scripting-engine flaws such as CVE-2018-4878 (Flash) and CVE-2018-8174 (VBScript) [19, 20].

2.3 Detection of exploit kits and C2 traffic

Detection research has pursued both content and behaviour. Cova *et al.* and Rieck *et al.* proposed analysis and detection of malicious JavaScript in drive-by attacks [21, 22]; WebWinnow exploited exploit-kit workflow regularities in URLs [23]; and Kizzle generated signatures automatically for polymorphic exploit-kit code [24]. On the network side, signature engines such as Snort, Bro and Suricata inspect traffic against rule sets [25, 26, 27], and community rule sets such as Emerging Threats contain signatures for named exploit-kit URI structures and stealer exfiltration [28]. For C2 detection, BotSniffer, BotMiner and behavioural-clustering approaches exploit the regularity of bot communication, including HTTP-based malware that repeatedly contacts server-side scripts [29, 30, 31]. These works motivate the focus here on repeated POST requests to a fixed script path.

2.4 Information stealers and KPOT

KPOT Stealer is a C/C++ stealer that targets account data in browsers, messaging, email, VPN, FTP, cryptocurrency and gaming software, uses HTTP for command and control, and was distributed through both email campaigns and exploit kits from August 2018 [3]. A later version was sold on underground forums for about US$100 [32]. This contrasts with Emotet, a modular banking Trojan and downloader spread mainly by malicious email and known for worm-like propagation [33, 34], a difference that matters when attributing traffic to a malware family (Section 5.5).

2.5 Gap addressed

Prior work largely addresses detection algorithms or ecosystem measurement. Fewer accessible studies show how an analyst, starting from a raw capture and IDS alerts, systematically moves from triage to a corroborated incident narrative while testing alternative explanations. This report addresses that gap using a public training dataset [7] and publicly documented host-identification techniques [35].

3. Methodology

3.1 Research design

The study is a retrospective, single-case, evidence-driven forensic analysis. A single case permits depth and full reproducibility, and the work is entirely *passive*: the malware sample is hashed but never executed, which removes the risk of live infection and keeps the analysis within the forensic principle of not altering evidence [2]. The design follows the four NIST SP 800-86 phases, with the Kill Chain used to order findings and ATT&CK to label behaviours [2, 10, 11].

3.2 Data sources and scenario

Three artefacts from the public exercise were used [7, 36]: (a) the packet capture 2019-06-22-traffic-analysis-exercise.pcap (4,694,048 bytes; 7,103 packets as shown by Wireshark); (b) the IDS alert export for the same capture; and (c) the executable retrieved from the infected Windows host. The scenario states a LAN of 10.0.76.0/24, domain phenomenoc.com, domain controller 10.0.76.6 and gateway 10.0.76.1. Because the dataset is a published training exercise, no real organisation or individual is affected.

3.3 Tools and environment

Tool	Purpose in this study
Wireshark [37]	Packet dissection, display filters, Endpoints/Conversations statistics, Export Objects, stream following
IDS alert console (RealTime/Escalated Events view)	Triage of signature alerts by source, destination, port and message [28]
Kali Linux, sha256sum	Cryptographic hashing of the extracted executable for identification and integrity
Reference material	NIST SP 800-61/86, Kill Chain, MITRE ATT&CK, Unit 42 host-identification guide [2, 8, 10, 11, 35]

3.4 Analytical workflow

Figure 1 summarises the six-stage workflow. Each stage has a defined question, technique and expected evidence, so that every conclusion can be traced to observable data.

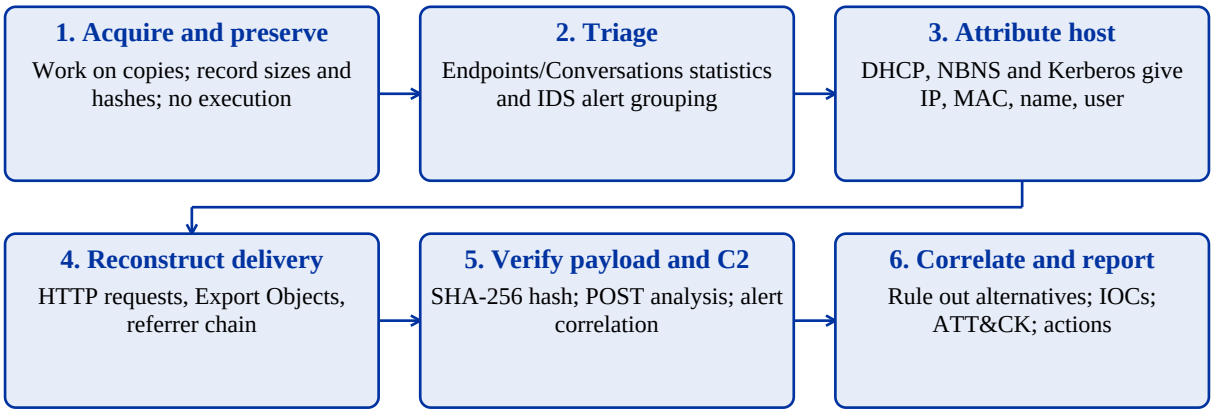


Fig. 1. Six-stage network-forensic workflow used in this study.

3.5 Procedure details and justification

Stage	Technique (display filter / command)	Justification
Triage	Statistics > Endpoints, Conversations; group IDS alerts by internal IP and signature class	Narrows hundreds of hosts and flows to the few that generate exploit or trojan-class alerts
Host attribution	bootp (DHCP); nbns; kerberos.CNameString with ip.src == host	DHCP binds IP to MAC and name [38]; in Kerberos AS-REQ, names ending in $ are machines and others are users [35, 39]
Delivery	http.request; File > Export Objects > HTTP; Follow TCP Stream	Plain HTTP exposes URIs, hosts, content types and sizes [40]
Payload	sha256sum <file>	A cryptographic hash uniquely identifies the sample for reputation and sharing
Post-infection	http.request.method == "POST"; inspect Host, URI, body length	Repeated POSTs to a fixed script are a recognised C2/exfiltration pattern [29, 31]
Correlation	Match alert time, IP and port to packets; test alternative hypotheses	A finding is accepted only if supported by at least two independent evidence types

3.6 Validity, limitations and ethics

Validity. Findings are triangulated: for example, the infected host is supported by IDS alerts, HTTP objects and traffic volumes simultaneously. IOCs are defanged (for example 8.209.83[.]76) to prevent accidental contact. **Limitations.** Only one capture and one sample are available; there is no endpoint disk or memory evidence and no sandbox detonation, so the precise exploit that succeeded and the exact data stolen cannot be proven. IDS signature names can mislabel families, so attribution is treated as *assessed* rather than certain. **Ethics.** The data are public training material, and the sample was handled only as an inert file.

4. Implementation Details

4.1 Environment and evidence handling

The capture was opened read-only in Wireshark on a Kali Linux virtual machine. The extracted executable was kept as a non-executable file and hashed. Table 1 is the evidence register.

Table 1. Evidence register.

Item ID	Evidence description	Hash (SHA-256)	Source / notes
EV-001	Executable retrieved from the infected Windows host	39be5610259ffade85599720ee0af31187788a00791f1e4cb0cd05ef00105eda	Exercise archive “malware retrieved from the infected Windows host” [7]; hash computed with sha256sum (Fig. 5)
EV-002	Packet capture 2019-06-22-traffic-analysis-exercise.pcap	6a89013b9e9bc6d443810245b92f49db4df33c1671a43db03a6bbde8f2bc6e63	4,694,048 bytes; 7,103 packets; 22 Jun 2019 23:46:30–23:50:22 UTC [7]
EV-003	IDS alert export	f4a1ef1b4df458de318e4030e2ac3ff1bc5d38212304e6f1bf5a8cc79d5667e3	Exercise archive [7]; text export, also viewed in alert console (Fig. 3)

4.2 Step 1 – Capture triage

Statistics > Endpoints (IPv4) lists every address with packet and byte counts (Fig. 2). The LAN contains the domain controller 10.0.76.6 and several workstations, and among external addresses 37.46.135.170 (about 1,031 packets, 1 MB) and 8.209.83.76 (1,015 packets, 751 kB) stand out. Notably, 8.209.83.76 *received* about 722 kB but sent only about 29 kB, an upload-dominated profile unusual for ordinary browsing and consistent with data exfiltration.

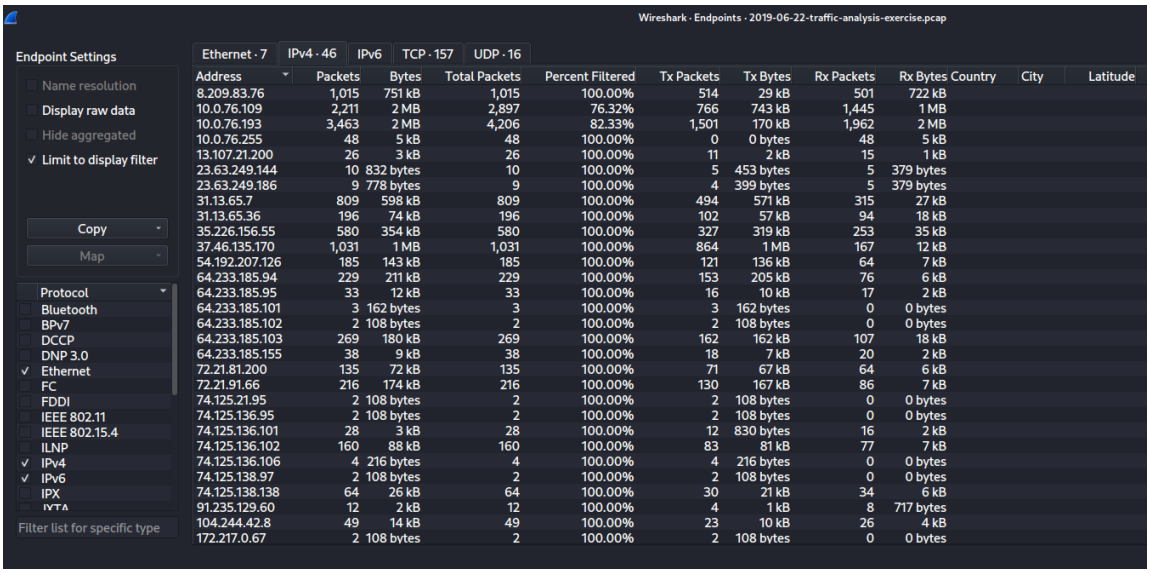


Fig. 2. Wireshark Endpoints (IPv4) view of the capture (display-filtered statistics).

4.3 Step 2 – IDS alert triage

The alert console (Fig. 3) shows alerts from two internal addresses. Table 2 groups the alerts by role in the attack. The exploit-kit and trojan classes involve 10.0.76.109, whereas 10.0.76.193 appears only in low-severity policy and web-bug alerts.

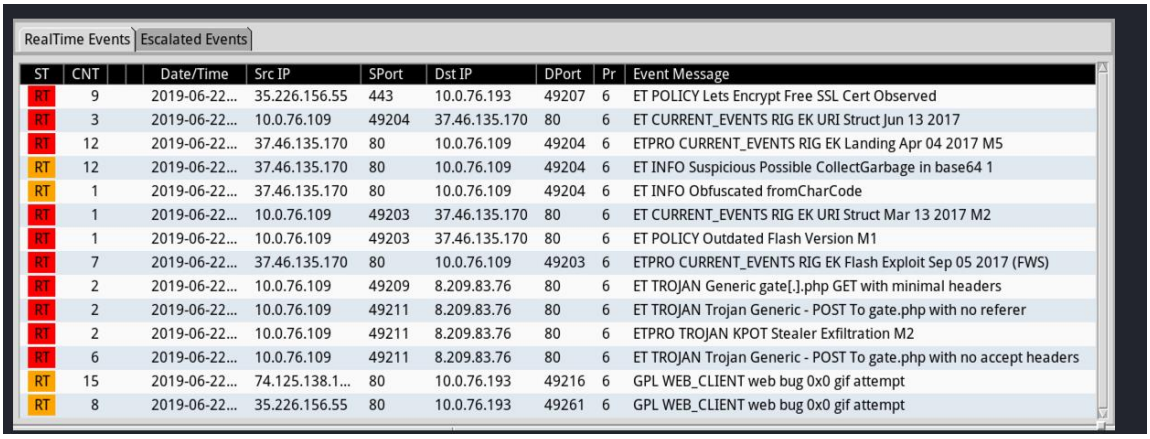


Fig. 3. IDS alerts for the capture (RealTime Events).

Table 2. Alert signatures grouped by role (counts read from Fig. 3).

Role	Signature (abbreviated)	Count
Exploit-kit delivery	ET CURRENT_EVENTS RIG EK URI Struct (Jun 13 2017; Mar 13 2017 M2)	3 + 1
Exploit-kit delivery	ETPRO CURRENT_EVENTS RIG EK Landing Apr 04 2017 M5	12
Exploit-kit delivery	ETPRO CURRENT_EVENTS RIG EK Flash Exploit Sep 05 2017 (FWS)	7
Exploit-kit delivery	ET INFO Suspicious Possible CollectGarbage in base64; Obfuscated fromCharCode	12 + 1
Exposure	ET POLICY Outdated Flash Version M1	1
Post-infection / C2	ET TROJAN Generic gate.php GET with minimal headers	2
Post-infection / C2	ET TROJAN Trojan Generic - POST To gate.php with no referer	2
Post-infection / C2	ET TROJAN Trojan Generic - POST To gate.php with no accept headers	6
Post-infection / C2	ETPRO TROJAN KPOT Stealer Exfiltration M2	2
Low severity (second host)	ET POLICY Lets Encrypt Free SSL Cert Observed; GPL WEB_CLIENT web bug 0x0 gif attempt	9; 15 + 8

4.4 Step 3 – Host attribution

The IDS source and destination fields identify 10.0.76.109 as the internal endpoint exchanging the RIG and trojan traffic. Its hardware address is 78:2b:cb:d4:a5:fe (shown by Wireshark with a Dell vendor prefix, Fig. 6) and its host name is BANGKOK-8AC2-PC, obtained from DHCP traffic. The commands used were bootp && ip.addr == 10.0.76.109 to read the DHCP host name and MAC, and kerberos.CNameString && ip.src == 10.0.76.109 to read the account name from the AS-REQ sent to the domain controller, discarding principals ending in $ (machine accounts) [35, 39]. The Windows user account on this host is **edris.haight** (domain PHENOMENOC); the same AS-REQ names the machine account BANGKOK-8AC2-PC$. By contrast, 10.0.76.193 is a different machine (Bristol-C71F-PC, MAC 00:1f:cf:61:19:64) with user setsuko.overton.

4.5 Step 4 – Delivery reconstruction

File > Export Objects > HTTP (Fig. 4) lists objects served over unencrypted HTTP. Four objects from 37.46.135.170, which is addressed by IP rather than a domain name, form the delivery sequence (Table 3). Their long, randomised query-string file names agree with the RIG URI-structure alerts in Table 2.

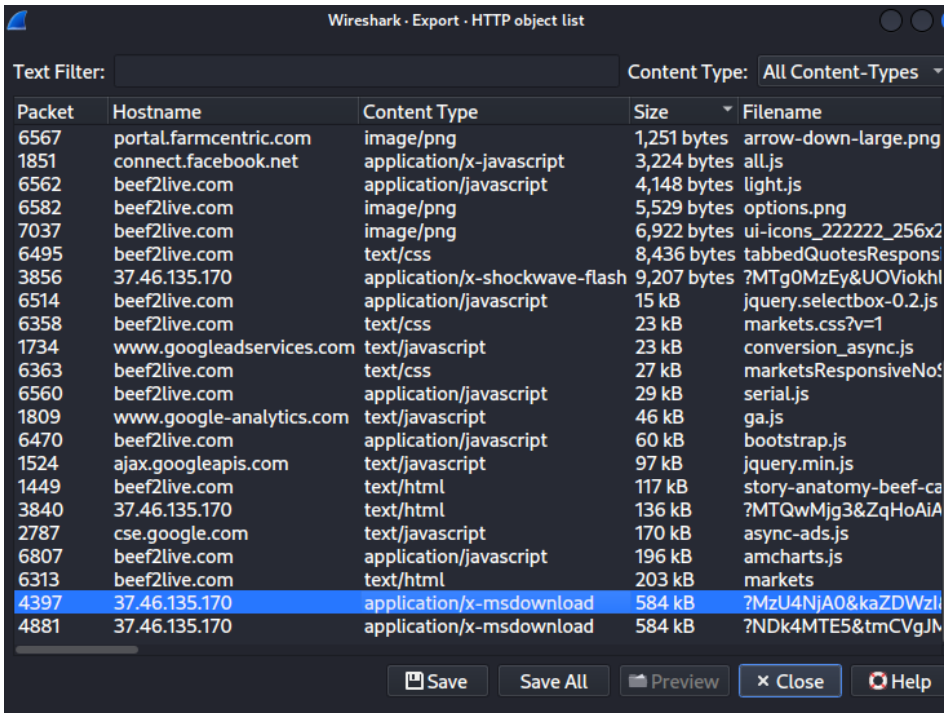


Fig. 4. Wireshark HTTP object list; the highlighted entry is packet 4397 (37.46.135.170, application/x-msdownload, 584 kB).

Table 3. Objects served by 37.46.135.170 (from Fig. 4).

Packet	Content type	Size	Interpretation
3840	text/html	136 kB	Exploit-kit landing page (obfuscated script; RIG landing alerts)
3856	application/x-shockwave-flash	9,207 bytes	Flash exploit object (RIG Flash exploit alerts)
4397	application/x-msdownload	584 kB	Executable payload download
4881	application/x-msdownload	584 kB	Second payload download of the same size

4.6 Step 5 – Payload fingerprinting

The executable retrieved from the infected host was hashed with sha256sum (Fig. 5). The resulting value, 39be5610259ffade85599720ee0af31187788a00791f1e4cb0cd05ef00105eda, is recorded as EV-001. Exploit kits commonly deliver the payload in a transformed (for example encrypted) form, so a hash of the on-wire object and of the executable recovered from the host are not expected to be identical; the hash in this report refers specifically to the host-recovered executable.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ sha256sum 2019-06-22-malware-retrieved-from-the-infected-Windows-host.exe
39be5610259ffade85599720ee0af31187788a00791f1e4cb0cd05ef00105eda  2019-06-22-malware-retrieved-from-the-infected-Windows-host.exe
```

Fig. 5. SHA-256 of the executable retrieved from the infected host (Kali Linux).

4.7 Step 6 – Post-infection traffic analysis

Filtering with http.request.method == "POST" (Fig. 6) reveals POST requests from 10.0.76.109 to 8.209.83.76 for a script named gate.php (path /gQBljYzDJBnrt4JX/gate.php), with the Host header fghjkmgru34.site. Two GET requests (23:48:23 and 23:48:27 UTC) are followed by two POSTs (23:48:28 and 23:48:29 UTC) with Content-Length 346,854 and 347,545 bytes. The POSTs carry *Content-Type: application/octet-stream*, are reassembled from many TCP segments, and have no Referer header. The KPOT Stealer exfiltration signature fired on this communication (Fig. 7).

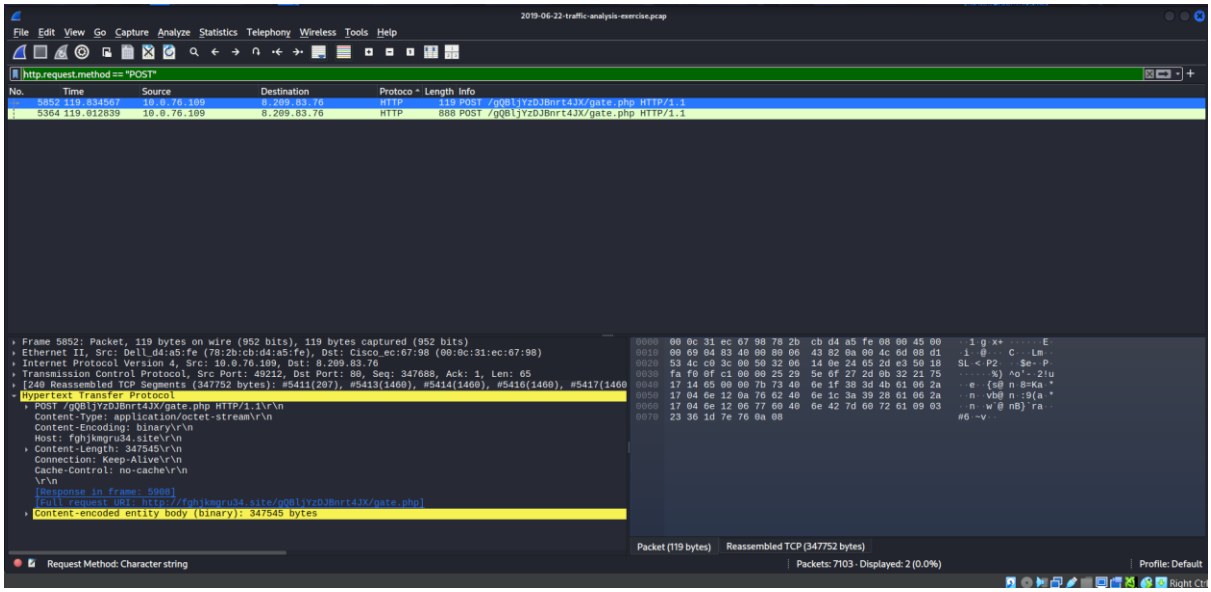


Fig. 6. HTTP POST requests to gate.php (frames 5052 and 5364); request detail shows Host fghjkmgru34.site and Content-Length 347545.

RT	2	2019-06-22...	10.0.76.109	49211	8.209.83.76	80	6	ETPRO TROJAN KPOT Stealer Exfiltration M2

Fig. 7. IDS alert: ETPRO TROJAN KPOT Stealer Exfiltration M2 (10.0.76.109 to 8.209.83.76:80).

5. Results and Discussion

5.1 Summary of findings

Table 4. Findings mapped to the investigation objectives.

Question	Finding	Supporting evidence
Infected host (O1)	10.0.76.109; MAC 78:2b:cb:d4:a5:fe; host name BANGKOK-8AC2-PC	IDS alerts, HTTP traffic, DHCP; Fig. 3, 4, 6
User account (O1)	edris.haight (domain PHENOMENOC)	Kerberos AS-REQ from 10.0.76.109
Delivery method (O2)	Drive-by download via RIG exploit kit over unencrypted HTTP (landing page, Flash exploit, payload)	Table 2 and Table 3
Delivery IP (O2)	37.46.135[.]170	Fig. 4; alerts with source 37.46.135.170
Executable hash (O3)	SHA-256 39be5610259ffade85599720ee0af31187788a00791f1e4cb0cd05ef00105eda	Fig. 5
Malware type (O4)	KPOT Stealer (information stealer), assessed from IDS signature and behaviour	Fig. 7; Table 2
Post-infection IP (O4)	8.209.83[.]76 (fghjkmgru34[.]site), HTTP POST to gate.php	Fig. 2, 6, 7

5.2 Reconstructed infection chain

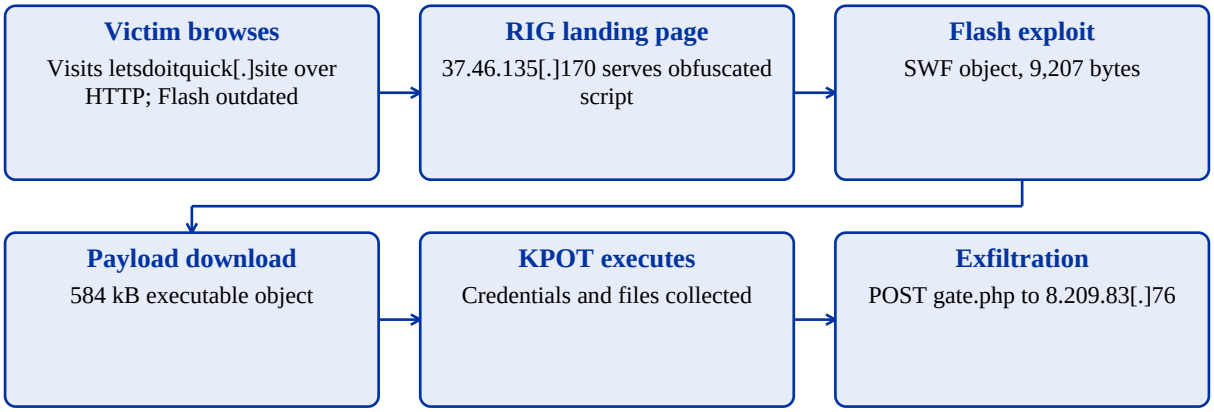


Fig. 8. Reconstructed infection chain.

The sequence follows the Kill Chain [10]: delivery and exploitation (steps 1–3), installation (steps 4–5) and command and control with actions on objectives (step 6). The IDS flagged an outdated Flash version on the victim, identifying the exposure that the exploit kit relied on.

5.3 Indicators of compromise

Table 5. Defanged IOC list.

Type	Indicator	Context
IPv4 (delivery)	37.46.135[.]170	RIG EK landing page, Flash exploit and payload (HTTP, port 80)
IPv4 (C2)	8.209.83[.]76	gate.php POST exfiltration (HTTP, port 80)
Domain (C2)	fghjkmgru34[.]site	Host header on POSTs to 8.209.83[.]76
URI path	/gQBljYzDJBnrt4JX/gate.php	Two GETs then two POSTs (Content-Length 346,854 and 347,545 bytes)
SHA-256	39be5610259ffade85599720ee0af3118778 8a00791f1e4cb0cd05ef00105eda	Executable retrieved from infected host
Host artefacts	10.0.76.109; 78:2b:cb:d4:a5:fe; BANGKOK-8AC2-PC	Affected endpoint
Domain / IPv4 (redirect)	letsdoitquick[.]site / 91.235.129[.]60	First request of the chain (23:48:04 UTC); the victim contacted 37.46.135[.]170 one second later
User account	edris.haight (PHENOMENOC)	Account active on the infected host; treat its credentials as stolen

5.4 Mapping to MITRE ATT&CK

Table 6. Observed behaviour mapped to ATT&CK techniques.

Technique	Observation in this case
Drive-by Compromise (T1189) [41]	Browser served exploit-kit landing page over HTTP
Exploitation for Client Execution (T1203) [42]	Flash object delivered to the outdated plug-in
Obfuscated Files or Information (T1027) [43]	Obfuscated script alerts (fromCharCode, CollectGarbage in base64)
Web Protocols (T1071.001) [44]	C2 over HTTP POST to gate.php
Exfiltration Over C2 Channel (T1041) [45]	347,545-byte POST bodies sent to the C2 server
Credentials from Web Browsers (T1555.003) [46]	Expected stealer capability per KPOT reporting [3]; not directly observable in the capture

5.5 Discussion

(a) Delivery is a drive-by, not email. The first malicious interaction is a browser-style HTTP request to an exploit-kit server, followed by a Flash object and a binary download, which matches the behaviour documented for exploit kits [15, 16, 17]. Because the traffic is unencrypted, the complete chain is recoverable from the capture; encryption would have reduced visibility to metadata.

(b) Malware family: KPOT rather than Emotet. The post-infection alerts name KPOT Stealer exfiltration and generic gate.php POST behaviour. KPOT is documented as an HTTP-based stealer distributed through exploit kits and email [3]. Emotet, by contrast, is documented as a banking Trojan and downloader spread mainly through malicious email

attachments and links, with worm-like lateral spread [33, 34]. Neither an email delivery step nor lateral movement is present in the capture, and no Emotet-named signature fired, so an Emotet attribution is not supported. The family is nevertheless reported as *assessed* because signatures can mislabel samples [28].

(c) Why the second busy host is excluded. 10.0.76.193 generates more packets than 10.0.76.109 (Fig. 2) but its alerts are limited to a Let's Encrypt certificate policy notice and web-bug image requests, which are low-severity browsing artefacts. It has no exploit-kit or trojan alert and no connection to 8.209.83.76. Packet volume alone therefore does not indicate compromise; alert class and destination reputation matter more.

(d) Internal versus external addresses. 10.0.76.109 lies in the private range reserved by RFC 1918 [47] and is the *victim*, not the source of delivery. The external delivery address is 37.46.135.170. Confusing source and destination is a common analytical error that would misdirect blocking and scoping.

(e) Impact. A POST body of 347,545 bytes sent to the C2 server, together with the profile of 8.209.83.76 receiving about 722 kB, indicates substantial data leaving the host. For a stealer, the exposed assets are saved credentials, session data and files [3]. This is the central operational risk, given that infostealer logs increasingly contain enterprise identity credentials [5]. The exact contents cannot be proven from the capture.

(f) Detection opportunities. The IDS detected the compromise through RIG URI-structure and landing-page signatures and a KPOT exfiltration signature [28]. Earlier prevention was possible at three points: patching or removing Flash, blocking the delivery IP, and blocking HTTP POST to unknown hosts without a Referer.

(g) Limitations. As stated in Section 3.6, there is no endpoint evidence and no sandbox run, so the exploited vulnerability, persistence behaviour and stolen data remain unverified.

5.6 Containment, eradication and recovery

Table 7. Recommended actions, aligned with NIST SP 800-61 [8].

Phase	Action	Rationale
Containment	Isolate 10.0.76.109 from the network; block 37.46.135[.]170, 8.209.83[.]76 and fghjkmgru34[.]site at the firewall, proxy and DNS	Stops further exfiltration and re-infection
Eradication	Re-image BANGKOK-8AC2-PC from a known-good image	Removes malware with certainty; manual cleaning cannot prove removal
Credential recovery	Reset the user's domain password; revoke sessions and tokens; reset every credential saved in browsers or applications on the host, including VPN, email and cloud accounts	Stealers copy credentials and sessions, so re-imaging alone does not invalidate stolen secrets [3, 5]
Scoping	Search proxy, DNS and firewall logs for the IOCs across all hosts; check authentication logs for the account after the infection time	Detects other victims and misuse of stolen credentials
Prevention	Remove Flash and keep browsers and plug-ins patched; restrict outbound HTTP; use web filtering and TLS inspection where permitted; deploy EDR	Removes the exploited exposure [6] and shortens dwell time
Detection engineering	Alert on large POSTs with application/octet-stream and no Referer to rare destinations; keep the ET rule set updated	Generalises beyond this one sample [28, 31]
Post-incident	Document timeline and lessons learned; add IOCs to threat-intelligence feeds; run awareness training	Completes the NIST lifecycle [8]

6. Conclusion

This case study showed that a passive, structured analysis of a single packet capture and its IDS alerts is sufficient to identify the compromised endpoint, reconstruct a complete drive-by infection chain, fingerprint the delivered executable and characterise stealer exfiltration. The compromised host 10.0.76.109 was infected through a RIG exploit-kit chain hosted on 37.46.135.170, the retrieved executable has the SHA-256 value listed in Table 5, and the host then uploaded large POST bodies to gate.php on 8.209.83.76 (fghjkmgru34.site), activity attributed to KPOT Stealer. Testing alternative explanations ruled out Emotet and the second busy host.

The main practical lesson is that stealer incidents are credential incidents: eradication by re-imaging must be paired with revocation of every secret the host could have held. Future work includes sandbox detonation of the sample to confirm the targeted applications, memory forensics on an endpoint image, automated extraction of IOCs from captures, and extending the methodology to encrypted (TLS) infection traffic, where analysts must rely on certificate, JA3-style and flow metadata.

References

[1] S. Davidoff and J. Ham, *Network Forensics: Tracking Hackers through Cyberspace*. Upper Saddle River, NJ, USA: Prentice Hall, 2012.

[2] K. Kent, S. Chevalier, T. Grance, and H. Dang, "Guide to integrating forensic techniques into incident response," NIST Special Publication 800-86, 2006. doi:

10.6028/NIST.SP.800-86

[3] D. Schwarz and Proofpoint Threat Insight Team, "New KPOT v2.0 stealer brings zero persistence and in-memory features to silently steal credentials," *Proofpoint*, May 9, 2019. [Online]. Available: https://www.proofpoint.com/us/blog/threat-insight/new-kpot-v20-stealer-brings-zero-persistence-and-memory-features-silently-steal

[4] "Infostealers harvest 1.7 billion credentials in six months" (reporting Flashpoint, *2026 Global Threat Intelligence Report: Midyear Edition*), *Infosecurity Magazine*, 2026. [Online]. Available: https://www.infosecurity-magazine.com/news/infostealers-17-billion/

[5] Flare, "Flare research warns 1 in 5 infostealer infections could yield enterprise credentials in 2026" (*2026 State of Enterprise Infostealer Exposure*), GlobeNewswire, Feb. 2, 2026. [Online]. Available: https://www.globenewswire.com/news-release/2026/02/02/3230348/0/en/Flare-Research-Warns-1-in-5-Infostealer-Infections-Could-Yield-Enterprise-Credentials-in-2026.html

[6] Adobe, "Adobe Flash Player end of life." [Online]. Available: https://www.adobe.com/products/flashplayer/end-of-life.html

[7] B. Duncan, "2019-06-22 – Traffic analysis exercise – Phenomenoc," *Malware-Traffic-Analysis.net*, Jun. 2019. [Online]. Available: https://malware-traffic-analysis.net/2019/06/22/index.html

[8] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, "Computer security incident handling guide," NIST Special Publication 800-61 Rev. 2, 2012. doi: 10.6028/NIST.SP.800-61r2

[9] P. Kral, "The incident handlers handbook," SANS Institute, 2011.

[10] E. M. Hutchins, M. J. Cloppert, and R. M. Amin, "Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains," in *Proc. 6th Int. Conf. Information Warfare and Security (ICIW)*, 2011, pp. 113–125.

[11] B. E. Strom *et al.*, "MITRE ATT&CK: Design and philosophy," The MITRE Corporation, Technical Report, 2018 (rev. 2020).

[12] R. Bejtlich, *The Practice of Network Security Monitoring: Understanding Incident Detection and Response*. San Francisco, CA, USA: No Starch Press, 2013.

[13] C. Sanders, *Practical Packet Analysis: Using Wireshark to Solve Real-World Network Problems*, 3rd ed. San Francisco, CA, USA: No Starch Press, 2017.

[14] N. Provos, D. McNamee, P. Mavrommatis, K. Wang, and N. Modadugu, "The ghost in the browser: Analysis of web-based malware," in *Proc. 1st USENIX Workshop on Hot Topics in Understanding Botnets (HotBots)*, 2007.

[15] N. Provos, P. Mavrommatis, M. A. Rajab, and F. Monrose, "All your iFRAMEs point to us," in *Proc. 17th USENIX Security Symposium*, 2008, pp. 1–15.

[16] C. Grier *et al.*, "Manufacturing compromise: The emergence of exploit-as-a-service," in *Proc. ACM Conf. Computer and Communications Security (CCS)*, 2012, pp. 821–832.

[17] V. Kotov and F. Massacci, "Anatomy of exploit kits: Preliminary analysis of exploit kits as software artefacts," in *Engineering Secure Software and Systems (ESSoS)*, LNCS vol. 7781, Springer, 2013, pp. 181–196.

[18] A. Nappa, M. Z. Rafique, and J. Caballero, "Driving in the cloud: An analysis of drive-by download operations and abuse reporting," in *Detection of Intrusions and*

Malware, and Vulnerability Assessment (DIMVA), LNCS vol. 7967, Springer, 2013.

[19] NIST National Vulnerability Database, "CVE-2018-4878: Adobe Flash Player use-after-free vulnerability." [Online]. Available: https://nvd.nist.gov/vuln/detail/CVE-2018-4878

[20] NIST National Vulnerability Database, "CVE-2018-8174: Windows VBScript engine remote code execution vulnerability." [Online]. Available: https://nvd.nist.gov/vuln/detail/CVE-2018-8174

[21] M. Cova, C. Kruegel, and G. Vigna, "Detection and analysis of drive-by-download attacks and malicious JavaScript code," in *Proc. 19th Int. World Wide Web Conf. (WWW)*, 2010, pp. 281–290.

[22] K. Rieck, T. Krueger, and A. Dewald, "Cujo: Efficient detection and prevention of drive-by-download attacks," in *Proc. Annual Computer Security Applications Conf. (ACSAC)*, 2010, pp. 31–39.

[23] B. Eshete and V. N. Venkatakrishnan, "WebWinnow: Leveraging exploit kit workflows to detect malicious URLs," in *Proc. 4th ACM Conf. Data and Application Security and Privacy (CODASPY)*, 2014.

[24] B. Stock, B. Livshits, and B. Zorn, "Kizzle: A signature compiler for detecting exploit kits," in *Proc. IEEE/IFIP Int. Conf. Dependable Systems and Networks (DSN)*, 2016.

[25] M. Roesch, "Snort: Lightweight intrusion detection for networks," in *Proc. 13th USENIX Systems Administration Conf. (LISA)*, 1999, pp. 229–238.

[26] V. Paxson, "Bro: A system for detecting network intruders in real-time," *Computer Networks*, vol. 31, no. 23–24, pp. 2435–2463, 1999.

[27] Open Information Security Foundation, "Suricata: Network IDS, IPS and network security monitoring engine." [Online]. Available: https://suricata.io/

[28] Proofpoint, "Emerging Threats rulesets (ET Open and ET Pro)." [Online]. Available: https://rules.emergingthreats.net/

[29] G. Gu, J. Zhang, and W. Lee, "BotSniffer: Detecting botnet command and control channels in network traffic," in *Proc. 15th Network and Distributed System Security Symposium (NDSS)*, 2008.

[30] G. Gu, R. Perdisci, J. Zhang, and W. Lee, "BotMiner: Clustering analysis of network traffic for protocol- and structure-independent botnet detection," in *Proc. 17th USENIX Security Symposium*, 2008.

[31] R. Perdisci, W. Lee, and N. Feamster, "Behavioral clustering of HTTP-based malware and signature generation using malicious network traces," in *Proc. 7th USENIX Symp. Networked Systems Design and Implementation (NSDI)*, 2010.

[32] D. Bisson, "Updated version of KPOT stealer available for purchase on underground hacking forums," *IBM Security Intelligence*, May 14, 2019. [Online]. Available: https://securityintelligence.com/news/updated-version-of-kpot-stealer-available-for-purchase-on-underground-hacking-forums

[33] CISA and MS-ISAC, "Alert (TA18-201A): Emotet malware," *US-CERT*, Jul. 20, 2018. [Online]. Available: https://www.us-cert.gov/ncas/alerts/TA18-201A

[34] CISA and MS-ISAC, "Emotet malware," Alert AA20-280A, Oct. 2020. [Online]. Available: https://cisa.gov/news-events/cybersecurity-advisories/aa20-280a

[35] B. Duncan, "Wireshark tutorial: Identifying hosts and users," *Unit 42, Palo Alto Networks*. [Online]. Available: https://unit42.paloaltonetworks.com/using-wireshark-identifying-hosts-and-users/

[36] B. Duncan, "Traffic analysis exercises," *Malware-Traffic-Analysis.net*. [Online]. Available: https://www.malware-traffic-analysis.net/training-exercises.html

[37] Wireshark Foundation, "Wireshark user's guide." [Online]. Available: https://www.wireshark.org/docs/wsug_html_chunked/

[38] R. Droms, "Dynamic host configuration protocol," IETF RFC 2131, Mar. 1997. [Online]. Available: https://www.rfc-editor.org/info/rfc2131

[39] C. Neuman, T. Yu, S. Hartman, and K. Raeburn, "The Kerberos network authentication service (V5)," IETF RFC 4120, Jul. 2005. [Online]. Available: https://www.rfc-editor.org/info/rfc4120

[40] R. Fielding, M. Nottingham, and J. Reschke, "HTTP semantics," IETF RFC 9110, Jun. 2022. [Online]. Available: https://www.rfc-editor.org/info/rfc9110

[41] MITRE, "Drive-by compromise, Technique T1189," *MITRE ATT&CK*. [Online]. Available: https://attack.mitre.org/techniques/T1189/

[42] MITRE, "Exploitation for client execution, Technique T1203," *MITRE ATT&CK*. [Online]. Available: https://attack.mitre.org/techniques/T1203/

[43] MITRE, "Obfuscated files or information, Technique T1027," *MITRE ATT&CK*. [Online]. Available: https://attack.mitre.org/techniques/T1027/

[44] MITRE, "Application layer protocol: Web protocols, Technique T1071.001," *MITRE ATT&CK*. [Online]. Available: https://attack.mitre.org/techniques/T1071/001/

[45] MITRE, "Exfiltration over C2 channel, Technique T1041," *MITRE ATT&CK*. [Online]. Available: https://attack.mitre.org/techniques/T1041/

[46] MITRE, "Credentials from password stores: Credentials from web browsers, Technique T1555.003," *MITRE ATT&CK*. [Online]. Available: https://attack.mitre.org/techniques/T1555/003/

[47] Y. Rekhter *et al.*, "Address allocation for private internets," IETF RFC 1918, Feb. 1996. [Online]. Available: https://www.rfc-editor.org/info/rfc1918